Code Signing in Plain English

Oct 12, 2026 · @Sanjay Nagpal

What code signing is

Code signing puts a tamper-evident seal, carrying our company's verified name, on every program we ship to clients.

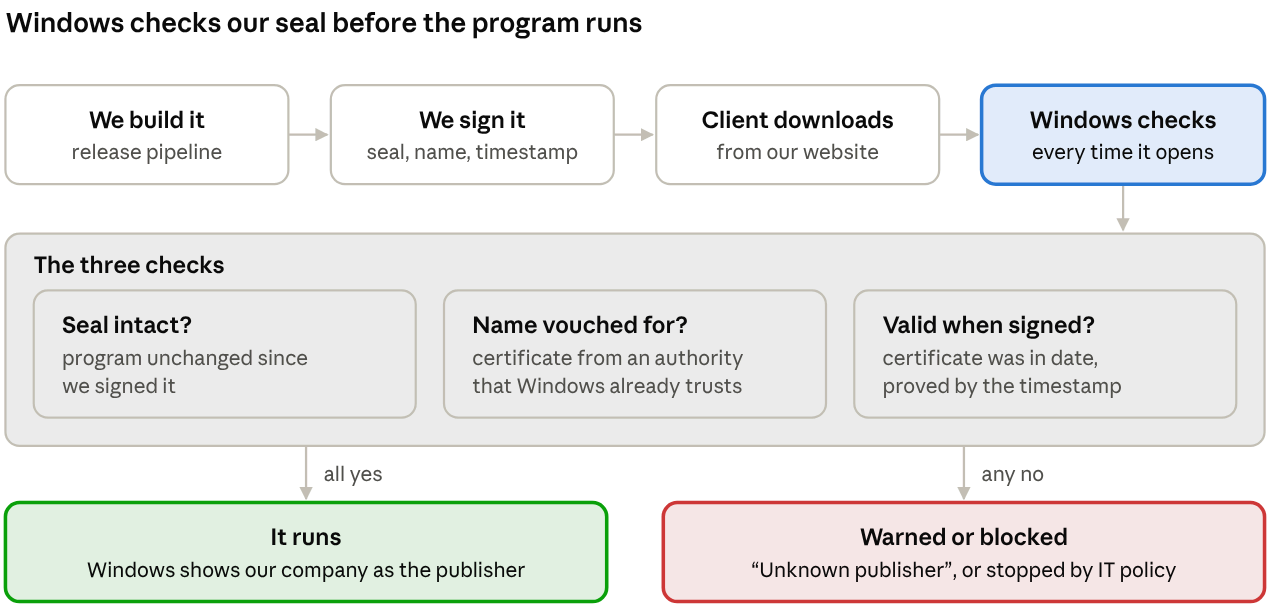
Think of a sealed letter from your bank. The seal tells you who sent it, and a broken seal tells you someone opened it on the way. Code signing does the same for software:

- **It shows who made the program.** An independent, trusted company called a Certificate Authority checks that we are a real, registered business. It then issues us a digital certificate in our name, like an ID card.
- **It shows nothing has changed.** If even one character of the program is altered after we sign it, by a virus or by someone tampering with the download, the seal breaks.

It does not promise the program is bug-free or harmless. It promises who stands behind it, and that what arrived is exactly what we sent.

How a client's computer checks the seal

Windows checks the seal automatically each time the program is opened. Nobody has to do anything by hand.



how a client's computer checks our seal · 3 checks

If all three checks pass, the program runs. If any check fails, Windows warns them or their IT policy blocks the program.

Why it matters to our clients

Without a valid signature, most corporate computers will warn about our program or refuse to run it at all.

IT and security teams lock down their Windows computers. They usually allow only software from publishers they have approved, and they recognize those publishers by their signature.

What the client receives	What their staff see
Signed, seal intact	Runs normally. Windows shows company as the verified publisher.
Not signed	"Unknown publisher" and "Windows protected your PC" warnings. Often blocked outright by company policy.
Signature broken or invalid	Treated as possibly tampered with. Blocked, and may be flagged to their security team.

An unsigned program also looks exactly like malware delivered by email or a fake website. Signing is how clients tell our genuine software apart from an imitation.

Two things we must manage

The seal is only trustworthy if our certificate is current and our signing key stays secret.

1. The certificate expires, like a passport. Certificates now last at most about 15 months, so renewal is a routine yearly task.

- Each signature also gets a **timestamp** from a trusted clock service. It proves we signed while the certificate was valid, so programs already shipped keep working after the certificate expires.
- We cannot sign new releases with an expired certificate. If renewal is late, releases stop. Renewal takes weeks, because the Certificate Authority re-checks our company.
- Our release process checks the expiry date before every signing and refuses to sign if it has passed. We also get alerts 60, 30 and 7 days ahead.

2. The signing key must stay locked away. Anyone who has the key can sign anything in our name, including malware.

- Industry rules have required the key to live in tamper-proof hardware, a Hardware Security Module (HSM), since June 2023. It can be used but never copied out.
- Our automated build system asks the HSM to sign each release. It never holds the key itself, and every use is logged.
- Only approved, official releases can trigger signing.

What is required

Signing is a small, recurring cost that decides whether clients can install our software at all.

- [ ] Choose a provider: a Certificate Authority such as DigiCert or Microsoft's managed signing service, which handles the key and renewals for us.
- [ ] Yearly cost of the certificate and secure key storage.
- [ ] Name an owner for renewal, and a shared mailbox for expiry alerts, so it never depends on one person.
- [ ] Agree who may approve a release for signing.

The technical detail is in the Windows Code Signing Playbook.